

iChat Pro 软件需求规格说明书

文档信息

项目	内容
文档名称	iChat Pro 软件需求规格说明书
文档类型	软件测试实践课程需求基线
文档版本	V2.0
编写日期	2026 年 9 月
编写小组	第七小组
项目负责人	叶伟智
评审人员	叶伟智
文档状态	本学期需求基线，待小组成员信息确认

修订记录

版本	日期	修订人	修订内容
V1.0	2026-09	GPT 5.6 生成	根据当前 iChat Pro 实现建立完整需求基线
V2.0	2026-09	GPT 5.6 生成	将既有功能调整为继承基线，新增 Windows/Android 产品化、云端部署、跨端通信及产业级测试需求
V2.1	2026-09	叶伟智	v2.0 文档表述修改，整体目标确定

1. 引言

1.1 编写目的

本文档完整描述 iChat Pro 的系统范围、用户角色、功能需求、界面需求、数据需求、外部接口、非功能需求、业务规则和验收原则。上学期已经实现的账号、联系人、聊天、端到端加密、文件传输和设置等能力在本文档中作为“继承功能基线”，用于保证兼容性和回归质量。

继承自上学期软件工程学的课程设计，本学期我们在原有课程设计的基础上继续完善，目标的建设内容是 **Windows/Android 客户端产品化、公网云部署、跨设备真实聊天和产业级测试体系**。

本文档明确区分“既有功能”和“本学期新增需求”。课程验收不得将旧功能的简单复现视为主要创新成果，也不得将界面占位或计划能力描述为已经完成。

1.2 项目名称

iChat Pro——基于端到端加密的轻量级即时通信系统。

1.3 项目背景

即时通信系统需要同时满足易用性、实时性、数据隔离和隐私保护要求。传统服务端明文存储消息的方式会扩大数据泄露风险。iChat Pro 以课程项目规模实现账号、联系人、私聊、群聊、实时消息、文件传输及设置管理等能力，并通过浏览器端加密降低服务端接触聊天明文和文件明文的机会。

本学期将原有项目继续用于软件测试实践。项目目标不仅是展示功能，还要以可验证的需求为起点，形成“需求—代码—测试用例—缺陷—修复—回归—报告”的完整证据链。

1.4 术语与缩写

术语	含义
E2EE	End-to-End Encryption，端到端加密
WebSocket	浏览器和服务端之间的全双工实时通信协议
密文	经客户端加密后、服务端不可直接读取的消息或文件内容
会话	私聊或群聊的逻辑容器
会话成员	用户与会话之间的成员关系，包含角色、未读数、静音等状态
密钥指纹	用于识别用户公钥版本的摘要标识
Mock Provider	无外部模型服务时返回模拟结果的 AI 服务实现
HTTP fallback	WebSocket 不可用时使用 HTTP 完成消息发送的备用通道
P0/P1/P2	高、中、低需求优先级

1.5 需求状态说明

状态	含义
已实现	当前代码中存在完整或基本完整的业务实现，可进入测试与验收
部分实现	已有模型、接口或界面，但能力或联动尚不完整
界面占位	仅展示入口、字段或提示，不应作为完整功能验收
规划	当前版本不承诺实现，仅保留未来方向

2. 系统总体说明

2.1 产品定位

iChat Pro 本学期定位为可真实安装、真实联网、真实跨设备通信，并具有完整质量保障体系的即时通信产品原型。系统继续复用现有 Django 和 Web 技术，但必须从本地演示模式升级为 Windows、Android 和浏览器共享云端服务的产品形态。

现有 SQLite、本地 Channel Layer 和开发服务器仅用于开发或单元测试，不作为公网正式部署方案。正式环境应采用 PostgreSQL、Redis、安全 ASGI 服务、HTTPS/WSS 和持久化文件存储。

2.2 系统目标

- 1. 将现有 Electron 原型升级为可安装、可运行、可卸载的 Windows App。
- 2. 基于现有 Web 能力提供可安装的 Android App，并完成移动端适配。
- 3. 将系统部署到公网云服务器，使不同地点和网络中的真实设备能够通信。
- 4. 使用 PostgreSQL、Redis、HTTPS/WSS 和持久化文件存储形成生产化基础架构。
- 5. 强化断线重连、消息幂等、状态同步和遗漏消息补取等可靠通信能力。
- 6. 在跨设备环境中明确设备身份、密钥保存、密钥变更和消息分发策略。
- 7. 保持现有账号、联系人、私聊、群聊、E2EE、文件和设置功能兼容可用。
- 8. 建立黑盒、白盒、接口、UI、安全、性能、兼容性和可靠性测试体系。
- 9. 建立自动化测试、覆盖率、依赖扫描、构建和部署组成的 CI/CD 质量门禁。
- 10. 形成需求、任务、代码、测试、缺陷、修复和回归完整可追溯链路。

2.3 技术架构



2.4 用户角色

角色	权限与主要目标
访客	注册、登录；不能访问联系人、会话及用户私有数据
普通用户	管理资料和联系人，参与私聊/群聊，管理个人设置和消息
群成员	接收群消息、发送消息、查看有效成员和群信息
群管理员	审核邀请、管理成员、维护群公告和群设置
群主	拥有群最高管理权限，可转让群主或解散群聊
系统管理员	使用 Django 管理后台管理基础数据并记录管理操作

2.5 运行环境与约束

- Python 3.13 及 Django 6.0 系列运行环境。
- Django Channels 提供 ASGI 和 WebSocket 支持。
- 默认使用 SQLite，开发环境可使用内存 Channel Layer，配置后可使用 Redis。
- Web 前端依赖现代浏览器的 JavaScript、WebSocket 和 Web Crypto API。
- Electron 仅作为桌面外壳，不实现独立业务逻辑。
- 项目不是完整前后端分离架构，页面由 Django Templates 渲染。
- 生产或正式演示环境必须使用独立密钥、关闭调试模式并启用 HTTPS。

3. 本学期新增建设需求

3.1 建设范围与成果定义

本学期不重复开发已有聊天功能，而是在既有系统上完成以下五类增量：

1. **客户端产品化**：形成真实可安装的 Windows App 和 Android App。
2. **服务云端化**：部署可从公网访问、支持持久化和安全通信的正式服务。
3. **通信可靠化**：支持跨网络、跨平台、断线重连、消息去重和状态同步。
4. **加密多设备化**：研究并实现适合多客户端的设备与密钥管理策略。
5. **测试工程化**：形成覆盖黑盒、白盒、安全、性能和兼容性的质量体系。

本学期成果必须能够通过安装包、云端地址、跨设备操作、自动化测试输出、覆盖率报告、缺陷记录和部署文档加以证明。仅展示旧页面或重新执行旧测试不能单独构成本学期主要成果。

3.2 Windows App 产品化需求

Windows 客户端继续使用 Electron 与现有 Web 前端，重点解决安装交付、系统集成、网络可靠性和敏感数据保护。

编号	需求	详细说明	优先级	验收要点
NEW-WIN-001	Windows 安装包	项目应生成普通用户可执行的 <code>.exe</code> 安装程序	P0	在干净的 Windows 测试环境完成安装并正常启动
NEW-WIN-002	安装与卸载	应支持安装目录选择或明确默认目录，并可从系统正常卸载	P0	卸载后程序入口移除；用户数据保留策略有明确说明
NEW-WIN-003	系统入口	安装程序应创建开始菜单入口，并允许创建桌面快捷方式	P1	入口图标、名称和启动目标正确
NEW-WIN-004	产品标识	窗口、安装器、快捷方式和关于页使用统一名称、图标和版本号	P1	不再出现 Electron 默认名称或图标

编号	需求	详细说明	优先级	验收要点
NEW-WIN-005	云服务连接	客户端连接配置的公网 HTTPS/WSS 服务	P0	无需在用户电脑运行 Django 即可登录聊天
NEW-WIN-006	窗口管理	支持最小化、最大化、关闭及合理的窗口尺寸限制	P1	各操作符合 Windows 使用习惯，界面不出现不可用区域
NEW-WIN-007	系统托盘	客户端可最小化至托盘，并从托盘恢复或退出	P1	托盘状态与应用进程一致，不产生不可见僵尸进程
NEW-WIN-008	系统通知	收到符合通知设置的新消息时显示 Windows 系统通知	P1	通知发送者、会话与实际消息一致；静音时不弹出
NEW-WIN-009	通知跳转	点击系统通知可打开应用并定位到有关会话	P2	应用未聚焦、最小化时均可正确恢复
NEW-WIN-010	文件集成	支持系统文件选择、加密上传、下载和安全打开文件	P1	文件类型、路径、权限和下载失败均有明确处理
NEW-WIN-011	连接状态	客户端显示在线、连接中、离线和重连失败状态	P0	用户能够区分服务故障与消息发送失败
NEW-WIN-012	自动重连	网络恢复后客户端自动重建 WebSocket 连接	P0	在验收网络条件下 30 秒内恢复连接
NEW-WIN-013	状态恢复	应用重启后可恢复非敏感界面状态和允许保留的登录状态	P1	不混用账号、会话或密钥状态
NEW-WIN-014	安全存储	Token、私钥和其他敏感凭据不得明文写入普通配置或日志	P0	静态检查和运行检查均未发现明文泄露
NEW-WIN-015	诊断日志	客户端记录版本、连接和错误诊断信息	P1	日志可定位问题，但不包含密码、完整 Token、私钥和聊天明文
NEW-WIN-016	版本更新	客户端提供版本信息和更新说明，自动更新作为增强目标	P2	用户可查看当前版本；更新失败不破坏现有安装

3.3 Android App 产品化需求

Android 客户端优先采用 Capacitor 或等价混合应用方案复用现有前端。不得仅提供浏览器网址或桌面页面截图作为 Android App 成果。

编号	需求	详细说明	优先级	验收要点
NEW-AND-001	Android 安装包	项目应生成可安装 APK，条件允许时同时生成 AAB	P0	至少一台真机或课程指定模拟器安装成功
NEW-AND-002	核心账号功能	App 支持注册、登录、退出和基本资料操作	P0	与浏览器和 Windows 使用同一云端账号
NEW-AND-003	核心聊天功能	App 支持联系人、私聊、群聊、历史消息和消息状态	P0	Android 与 Windows/浏览器可双向通信
NEW-AND-004	移动端布局	页面适配手机竖屏和至少一种横屏或大屏场景	P0	无关键按钮遮挡、横向溢出或无法滚动区域
NEW-AND-005	触摸交互	点击、长按、滑动、输入法和焦点行为适合触屏操作	P1	不依赖鼠标悬停才能完成核心操作
NEW-AND-006	系统返回键	返回键按页面层级关闭弹窗、返回列表或退出提示	P1	不因一次返回直接丢失输入或异常退出
NEW-AND-007	生命周期恢复	App 切入后台再返回时恢复登录、当前会话和连接状态	P0	后台恢复后不会重复发送消息或显示错误账号数据
NEW-AND-008	网络变化检测	能识别 Wi-Fi、移动网络和离线状态变化	P0	网络切换时显示状态并自动尝试恢复通信
NEW-AND-009	前台消息通知	App 在前台时以应用内方式提示新消息	P0	当前会话与其他会话提示逻辑正确
NEW-AND-010	后台系统通知	App 在后台时使用 Android 系统通知提示新消息	P1	通知权限、静音设置和点击跳转正确
NEW-AND-011	离线云推送	App 完全退出后仍可通过推送服务接收通知	P2	推送不包含不应暴露的消息明文；失败不影响消息保存
NEW-AND-012	文件选择	支持通过 Android 系统选择器选择图片和普通文件	P1	运行时权限、取消选择和无效文件均被正确处理
NEW-AND-013	文件保存	用户可将有权访问的文件保存到允许位置	P1	遵守 Android 存储权限和分区存储规则
NEW-AND-014	权限管理	仅在需要时申请通知、文件、相册或摄像头等权限	P0	拒绝权限后给出可理解提示，核心文本聊天仍尽量可用

编号	需求	详细说明	优先级	验收要点
NEW-AND-015	安全存储	设备私钥和登录凭据使用系统安全存储或等价保护	P0	不以明文保存在普通 Web Storage、共享目录或日志中
NEW-AND-016	Android 兼容性	至少在两个 API Level 或不同尺寸设备上完成测试	P1	核心流程结果一致，差异和限制有记录

3.4 跨平台一致性需求

编号	需求	详细说明	优先级	验收要点
NEW-XP-001	统一账号	Windows、Android 和浏览器共用同一云端用户体系	P0	任一平台注册账号可在其他平台登录
NEW-XP-002	数据一致性	联系人、会话、群组、设置和消息状态在不同客户端保持一致	P0	刷新或重新登录后服务端状态一致，不依赖单一设备本地数据
NEW-XP-003	协议一致性	三端使用统一 HTTP、WebSocket、消息和加密协议	P0	同一协议版本的客户端可互相解析消息
NEW-XP-004	文本互通	Windows、Android 和浏览器之间可双向发送文本消息	P0	消息内容、发送者、时间和状态一致
NEW-XP-005	文件互通	不同平台可发送、接收和解密支持的图片或文件	P1	文件摘要一致，越权设备不能下载或解密
NEW-XP-006	时间与顺序	客户端以服务端时间和稳定标识展示消息顺序	P0	设备本地时间偏差不导致明显乱序或重复
NEW-XP-007	版本兼容	客户端和服务端协议不兼容时给出升级或错误提示	P1	不静默丢弃消息，不将未知数据展示为正常消息
NEW-XP-008	状态同步	送达、已读、撤回、删除和群成员变化在相关客户端同步	P1	同一账号或会话参与者最终状态一致

3.5 公网云部署需求

正式云环境推荐采用如下结构：

windows App / Android App / Browser

↓ HTTPS / WSS

Nginx 反向代理

↓

Django ASGI / Daphne

↙

PostgreSQL

↘

Redis

↓

持久化磁盘或对象存储

编号	需求	详细说明	优先级	验收要点
NEW-CLD-001	公网域名	系统通过稳定的公网域名访问	P0	校外或不同网络的设备可解析并访问
NEW-CLD-002	HTTPS/WSS	页面、API、文件和 WebSocket 全部使用安全连接	P0	HTTP 自动跳转 HTTPS; 客户端使用 <code>wss://</code>
NEW-CLD-003	反向代理	使用 Nginx 或等价组件终止 TLS 并代理 HTTP/WebSocket	P0	WebSocket 升级、超时和上传大小配置正确
NEW-CLD-004	正式 ASGI 服务	使用 Daphne 或等价 ASGI 服务运行 Django	P0	正式环境不使用 <code>manage.py runserver</code>
NEW-CLD-005	PostgreSQL	正式业务数据迁移至 PostgreSQL	P0	migrations 可执行, 重启/升级后业务数据完整
NEW-CLD-006	数据迁移	如需保留既有数据, 应提供 SQLite 到 PostgreSQL 的迁移方案	P1	迁移数量和关键关系校验一致
NEW-CLD-007	Redis Channel Layer	正式 WebSocket 消息分发使用 Redis	P0	多进程/多客户端场景消息可正确到达, Redis 不暴露公网
NEW-CLD-008	持久化文件	头像和聊天密文文件使用持久化磁盘或对象存储	P0	服务重启和应用升级后文件仍可访问
NEW-CLD-009	配置与密钥	密码、Secret Key、API Key 等通过环境变量或秘密管理配置	P0	Git 历史、仓库文件和普通日志中无生产密钥
NEW-CLD-010	服务托管	使用 systemd、Docker Compose 或等价方式管理服务	P0	服务异常退出后自动恢复, 开机可按配置启动

编号	需求	详细说明	优先级	验收要点
NEW-CLD-011	环境隔离	开发、测试和生产使用独立配置与数据	P0	测试不会修改生产数据库或生产文件
NEW-CLD-012	健康检查	提供不泄露敏感信息的服务健康检查	P1	可识别应用、数据库和必要依赖的可用状态
NEW-CLD-013	日志	记录访问、应用错误和关键安全事件	P1	日志可用于定位问题且不含密码、私钥、完整 Token 或聊天明文
NEW-CLD-014	监控告警	监控 CPU、内存、磁盘、进程、接口和证书状态	P1	资源不足、服务异常或证书临期能够产生告警
NEW-CLD-015	数据备份	定期备份 PostgreSQL 和必要持久化文件	P0	备份文件有时间、范围和保留策略记录
NEW-CLD-016	恢复演练	至少在独立测试环境完成一次数据恢复	P0	用户、关系、会话、消息和文件抽样校验成功
NEW-CLD-017	部署与回滚	提供自动或标准化部署步骤及失败回滚方案	P1	新版本失败后可恢复最近稳定版本且数据不损坏
NEW-CLD-018	网络边界	数据库和 Redis 不直接开放公网，防火墙仅放行必要端口	P0	外部扫描无法直接连接内部数据服务

3.6 真实聊天与可靠性需求

真实聊天验收至少使用两台不同设备和两个不同用户账号，并尽量处于不同网络环境。仅在同一浏览器的不同标签页操作不能作为最终跨端验收证据。

编号	需求	详细说明	优先级	验收要点
NEW-REL-001	跨网络聊天	不同公网网络中的用户可完成联系人、私聊和群聊	P0	Windows 与 Android 完成双向消息演示
NEW-REL-002	唯一消息 ID	客户端为每条待发送消息生成稳定唯一 ID	P0	重试期间 ID 不改变，不与其他消息冲突
NEW-REL-003	消息幂等	服务端识别重复提交并返回已有结果	P0	HTTP/WebSocket 重试不会产生重复逻辑消息

编号	需求	详细说明	优先级	验收要点
NEW-REL-004	发送状态机	客户端展示发送中、已发送、已送达、已读和失败状态	P0	状态转换有明确触发条件，不倒退为非法状态
NEW-REL-005	失败重试	发送失败时保留内容并允许用户重试	P0	不静默丢失，不因重试产生重复消息
NEW-REL-006	自动重连	网络恢复后客户端自动重新建立实时连接	P0	目标测试环境下 30 秒内恢复连接
NEW-REL-007	遗漏消息补取	重连后客户端获取断线期间有权接收的消息	P0	补取消息不重复、不越权且顺序正确
NEW-REL-008	消息排序	使用服务端时间和唯一标识形成稳定排序	P0	本地时间不一致时仍保持合理顺序
NEW-REL-009	状态最终一致	多客户端上的未读、已读、撤回等状态最终一致	P1	刷新或同步后不持续出现相互矛盾状态
NEW-REL-010	重启恢复	应用或服务重启后已确认消息和关系数据不丢失	P0	重启后抽样数据与重启前一致
NEW-REL-011	明确故障反馈	网络、认证、权限、存储或服务错误应显示可理解提示	P0	不显示无限加载、虚假成功或原始异常堆栈

3.7 多设备与密钥演进需求

多设备 E2EE 是本学期具有研究价值的增强方向。为控制工作量，采用分级交付：P0 确保单个可信设备安全工作；P1 支持多设备接收新消息；P2 研究经授权的历史迁移或恢复。

编号	需求	详细说明	优先级	验收要点
NEW-DEV-001	设备标识	每个客户端实例具有稳定且不可轻易冲突的设备标识	P1	同一账号不同设备可被区分和管理
NEW-DEV-002	独立设备密钥	每台设备独立生成和保存私钥，服务端只保存公钥	P1	一台设备的私钥不直接复制到其他设备或服务端
NEW-DEV-003	设备列表	用户可查看与账号关联的有效设备及最近活动时间	P1	只允许本人查看，信息足以识别异常设备
NEW-DEV-004	撤销设备	用户可撤销不再使用或可疑的设备	P1	被撤销设备不能继续接收新消息和密钥材料
NEW-DEV-005	多设备分发	发送消息时向接收者的有效设备分别准备可解密数据	P1	每个有效设备能解密新消息，撤销设备不能解密后续消息

编号	需求	详细说明	优先级	验收要点
NEW-DEV-006	新设备限制	新设备不得未经授权自动解密全部历史消息	P0	历史访问策略有明确提示和测试证据
NEW-DEV-007	密钥变化提示	联系人新增设备或密钥变化时提示重新验证	P1	新密钥不自动继承旧密钥的可信状态
NEW-DEV-008	安全存储适配	Windows 与 Android 分别使用适合平台的敏感信息保护机制	P0	普通文件、日志和 Web Storage 中无可直接读取私钥
NEW-DEV-009	历史迁移	经用户明确授权后，可采用安全方案迁移历史解密能力	P2	授权、加密、撤销和失败恢复过程有设计与测试

3.8 产业级测试体系需求

“产业级测试”在本项目中指测试活动具备分层覆盖、风险驱动、自动执行、量化指标、缺陷闭环和质量门禁，而不是单纯增加测试用例数量。

3.8.1 测试层次



编号	需求	详细说明	优先级	验收要点
NEW-TST-001	测试计划	建立范围、策略、环境、资源、进度、准入和准出标准	P0	计划经小组评审，并与需求优先级一致
NEW-TST-002	需求追踪	每项 P0/P1 需求关联任务、用例和执行结论	P0	追踪矩阵不存在无测试的 P0 需求
NEW-TST-003	黑盒测试	使用等价类、边界值、判定表、状态迁移和场景法	P0	用例注明采用方法，并覆盖正常、异常和边界场景
NEW-TST-004	探索性测试	对弱网、快速操作、切换账号和生命周期进行探索	P1	每次测试有章程、时间、发现和后续处理记录

编号	需求	详细说明	优先级	验收要点
NEW-TST-005	白盒测试	对核心逻辑执行语句、分支、条件、路径和异常流程测试	P0	报告同时展示语句与分支覆盖率，不只统计用例数量
NEW-TST-006	后端覆盖率	核心后端模块语句覆盖率目标不低于 85%	P0	使用可复现命令生成 HTML/XML/终端报告
NEW-TST-007	分支覆盖率	核心后端模块分支覆盖率目标不低于 75%	P0	未覆盖分支列出原因、风险和补测计划
NEW-TST-008	高风险覆盖率	认证、权限、幂等和加密边界等高风险逻辑覆盖目标不低于 90%	P0	对应模块和统计口径在测试计划中明确
NEW-TST-009	单元测试	模型、表单、工具函数和状态转换具备独立测试	P0	测试可重复、相互隔离且不依赖生产数据
NEW-TST-010	接口测试	HTTP API 覆盖方法、认证、权限、输入、状态码和副作用	P0	P0 接口包含成功、失败、越权和边界用例
NEW-TST-011	WebSocket 测试	覆盖连接认证、来源、事件、实时推送、断线和重连	P0	私聊和群聊不存在跨用户数据泄露
NEW-TST-012	数据库集成测试	在 PostgreSQL 环境验证迁移、约束、事务和查询	P0	不以 SQLite 测试完全替代正式数据库验证
NEW-TST-013	Redis 集成测试	验证真实 Redis Channel Layer 的消息分发	P0	多客户端或多进程消息能够到达正确用户
NEW-TST-014	浏览器 E2E	自动化执行注册、登录、联系人和聊天核心流程	P1	测试失败保存截图、日志或跟踪文件
NEW-TST-015	Windows App 测试	覆盖安装、卸载、升级、启动、通知、文件和异常恢复	P0	在干净 Windows 环境形成测试记录
NEW-TST-016	Android App 测试	覆盖安装、权限、生命周期、布局、通知和网络切换	P0	至少两个 API Level 或设备配置有执行记录

编号	需求	详细说明	优先级	验收要点
NEW-TST-017	跨端测试	Windows、Android 和浏览器组合执行消息与文件场景	P0	至少两台真实/独立设备完成双向验证
NEW-TST-018	安全测试	执行认证、越权、XSS、CSRF、注入、上传、SSRF 和秘密检查	P0	高危缺陷发布前清零，中危缺陷有明确处理结论
NEW-TST-019	依赖安全	检查 Python、Node.js 和 Android 依赖已知漏洞	P1	报告记录工具、数据库时间、风险和处置结果
NEW-TST-020	性能测试	对 HTTP、WebSocket、消息和文件场景执行基准与负载测试	P1	提供脚本、数据规模、环境和 P50/P95/P99 等结果
NEW-TST-021	弱网测试	模拟延迟、丢包、断网和网络切换	P0	验证提示、重连、补取、幂等和最终一致性
NEW-TST-022	稳定性测试	执行长时间运行和重复操作测试	P1	无服务崩溃、明显资源泄漏或静默数据损坏
NEW-TST-023	备份恢复测试	在独立环境验证数据库和文件恢复	P0	恢复后关键实体数量、关系和文件抽样一致
NEW-TST-024	缺陷管理	缺陷记录环境、步骤、预期、实际、严重程度、证据和状态	P0	每个已修复缺陷关联修复提交和复测结论
NEW-TST-025	回归测试	修复后执行原失败用例及相关模块自动化回归	P0	不因修复产生新的 P0/P1 回归失败
NEW-TST-026	测试总结	形成范围、执行率、通过率、覆盖率、缺陷和风险总结	P0	数字可由原始结果复核，不使用估算冒充实测

3.8.2 黑盒测试方法要求

黑盒测试至少包含：

- 等价类划分：账号、表单、搜索、文件和消息输入；
- 边界值分析：字段长度、文件大小、分块索引、分页、消息密文大小；
- 判定表：联系人、拉黑、成员角色和消息权限组合；
- 状态迁移：好友申请、群邀请、消息、文件和连接状态；
- 因果图：多条件权限判断及结果组合；

- 场景法：注册—加好友—跨端聊天—断网—恢复—补取；
- 错误推测：重复点击、重复提交、后台恢复、服务重启和磁盘不足；
- 探索性测试：跨平台交互、弱网和异常生命周期。

3.8.3 白盒测试方法要求

白盒测试至少包含：

- 语句覆盖和分支覆盖；
- 复合条件的真/假组合；
- 关键业务基本路径；
- 分页、分块和重试循环的零次、一次、典型及上限路径；
- 异常捕获、事务回滚和资源清理路径；
- 权限校验前后的数据流和副作用检查；
- 未覆盖代码的原因与风险说明。

3.8.4 安全测试范围

安全测试以 OWASP Top 10 和即时通信业务风险为参考，至少覆盖：

- SQL 注入、XSS、CSRF 和开放重定向；
- 身份认证绕过、账号枚举和会话固定；
- 水平越权、垂直越权和群角色越权；
- 文件类型欺骗、超大文件、路径穿越和未授权下载；
- AI 服务地址 SSRF；
- Cookie、HTTPS、CSP 和安全响应头；
- 日志、安装包、浏览器存储及移动端存储中的敏感信息；
- 服务端数据库、HTTP 和 WebSocket 中的 E2EE 明文泄露；
- Python、Node.js 和 Android 第三方依赖漏洞。

3.8.5 性能与稳定性基线

以下指标作为首版验收目标，执行前可根据云服务器配置形成经小组评审的调整记录：

指标编号	场景	首版目标
PERF-001	WebSocket 并发连接	100 个并发连接持续 10 分钟，无服务崩溃
PERF-002	消息吞吐	每秒 20 条聊天消息持续 10 分钟，无服务端重复记录
PERF-003	实时延迟	正常网络下 95% 消息在 1 秒内对接收端可见
PERF-004	HTTP 响应	95% 普通 API 请求不高于 500 ms
PERF-005	重连时间	网络恢复后客户端 30 秒内恢复实时连接
PERF-006	稳定运行	系统连续运行 24 小时，无导致服务退出的异常
PERF-007	数据恢复	最新有效备份可恢复到独立测试环境并通过抽样校验

3.9 CI/CD 质量门禁需求

建议使用 GitHub Actions 或等价平台实现持续集成与部署。所有质量结果必须保存为可追踪的日志或报告。

编号	需求	详细说明	优先级	验收要点
NEW-CI-001	静态检查	自动执行 Python/JavaScript 格式与静态分析	P0	检查失败时流水线失败
NEW-CI-002	Django 检查	自动执行系统检查和迁移一致性检查	P0	配置或遗漏迁移时禁止合并
NEW-CI-003	自动化测试	自动执行后端及前端加密测试	P0	任一核心测试失败时禁止发布
NEW-CI-004	覆盖率门禁	自动生成覆盖率并校验约定阈值	P0	低于阈值时流水线失败或需要有审批的例外记录
NEW-CI-005	安全扫描	自动执行依赖漏洞和秘密扫描	P1	高危漏洞或密钥泄露阻断发布
NEW-CI-006	客户端构建	自动或标准化构建 Windows 与 Android 安装包	P1	构建产物带版本号、校验值和流水线记录
NEW-CI-007	测试环境部署	主分支合格后部署到独立测试环境	P1	测试环境配置与生产隔离
NEW-CI-008	云端冒烟	部署后自动验证健康检查、登录和核心接口	P0	冒烟失败不得继续生产发布
NEW-CI-009	生产发布审批	正式部署前需要明确版本和人工审批	P1	可追踪发布人、版本、时间和变更范围
NEW-CI-010	回滚能力	发布失败时可恢复最近稳定版本	P1	回滚步骤经过演练且不破坏数据库

推荐测试和质量工具包括：

- `coverage.py`：Python 语句与分支覆盖率；
- Django Test 或 `pytest-django`：单元及集成测试；
- Playwright：浏览器与 Electron 端到端测试；
- Appium：Android UI 自动化测试；
- Locust 或 `k6`：性能与并发测试；
- OWASP ZAP：动态安全测试；
- Bandit：Python 静态安全检查；
- `pip-audit`、`npm audit`：依赖漏洞检查；
- Ruff、ESLint：格式和静态质量检查。

工具只有在实际配置并执行后才可列入最终实验结果；本节列出的推荐工具不等同于已经完成部署。

3.10 本学期优先级与交付物

3.10.1 P0 必须完成

- 公网域名、HTTPS/WSS、PostgreSQL 和 Redis;
- 可安装 Windows 客户端和 Android 客户端;
- Windows、Android 通过公网完成真实双向聊天;
- 断线重连、消息幂等、状态反馈和遗漏消息补取;
- 敏感数据和 E2EE 明文不进入服务端或普通日志;
- 黑盒、白盒、接口、安全和弱网测试;
- 覆盖率报告、缺陷闭环和 CI 核心质量门禁;
- 部署、备份、恢复和最终测试报告。

3.10.2 P1 应当完成

- Windows 托盘、系统通知和文件集成;
- Android 前后台恢复、系统通知和文件选择;
- 群聊与加密文件跨端验证;
- 多设备新消息分发和设备撤销;
- 浏览器/Electron/Android 自动化 UI 测试;
- 性能、稳定性、兼容性、日志、监控和告警;
- 测试环境自动部署及生产回滚演练。

3.10.3 P2 增强目标

- Android 完全退出后的云推送;
- Windows 自动更新;
- 经授权的多设备历史密钥迁移;
- 对象存储、灰度发布和更高并发测试。

3.10.4 预期交付物

1. Windows `.exe` 安装包及安装测试记录;
2. Android APK/AAB 及兼容性测试记录;
3. 公网域名、云端部署架构和可访问服务;
4. 部署、升级、回滚、备份和恢复手册;
5. 软件需求规格说明书、任务拆解和需求追踪矩阵;
6. 黑盒、白盒、接口、WebSocket 和端到端测试用例;
7. 覆盖率、安全、性能、弱网、兼容性和稳定性报告;
8. 缺陷清单、修复提交、复测和回归记录;
9. CI/CD 流水线及质量门禁运行证据;
10. Windows 与 Android 跨网络聊天截图或演示视频;
11. 最终软件测试总结报告。

4. 继承功能需求基线

本章记录上学期已经实现或部分实现的功能。它们是本学期客户端产品化、云端部署和测试工作的被测对象及回归基线，不作为本学期新增开发成果重复计分。若新架构导致既有功能退化，应登记为回归缺陷并修复。

4.1 账号注册、登录与会话

编号	需求	详细说明	优先级	状态	验收要点
FR-ACC-001	用户注册	访客可提交用户名、邮箱、密码及确认密码创建账号	P0	已实现	合法数据创建唯一账号；非法或重复数据不创建账号并提示原因
FR-ACC-002	注册后登录	注册成功后系统建立登录状态并进入主界面	P1	已实现	当前用户身份可被后续请求识别
FR-ACC-003	用户名登录	用户可使用用户名和密码登录	P0	已实现	正确凭据登录成功；错误凭据不建立会话
FR-ACC-004	邮箱登录	用户可使用已绑定邮箱和密码登录	P1	已实现	邮箱匹配不区分大小写，认证结果正确
FR-ACC-005	登录失败保护	登录失败使用通用提示，避免泄露账号是否存在	P0	已实现	不因账号不存在、密码错误而显示可枚举差异
FR-ACC-006	禁用账号处理	被禁用用户不能登录，并获得明确但安全的提示	P1	已实现	<code>is_active=False</code> 的用户认证失败
FR-ACC-007	安全跳转	登录/退出后的 <code>next</code> 地址只能指向同站安全路径	P0	已实现	外部或恶意跳转地址被忽略
FR-ACC-008	用户退出	已登录用户可退出当前会话	P0	已实现	退出后受保护页面不可继续访问
FR-ACC-009	登录保护	用户私有页面和接口必须验证登录状态	P0	已实现	未登录请求被重定向或返回拒绝结果
FR-ACC-010	活跃会话列表	用户可查看当前账号的有效会话信息	P2	已实现	只返回当前用户相关会话

编号	需求	详细说明	优先级	状态	验收要点
FR-ACC-011	终止会话	用户可终止指定的登录会话	P2	已实现	会话被删除或失效，不影响无关用户
FR-ACC-012	多账号上下文	系统保存当前用户的多账号本地上下文配置	P2	部分实现	上下文可读取和更新；完整跨账号认证切换不作为当前承诺

4.2 用户资料与头像

编号	需求	详细说明	优先级	状态	验收要点
FR-PRO-001	查看本人资料	用户可获取用户名、昵称、头像、简介等本人资料	P1	已实现	返回内容与当前登录用户一致
FR-PRO-002	编辑资料	用户可编辑允许修改的个人资料字段	P1	已实现	合法数据保存；非法格式和重复用户名被拒绝
FR-PRO-003	上传头像	用户可上传头像图片	P1	已实现	仅接受允许的图片格式和大小，文件与资料正确关联
FR-PRO-004	裁剪头像	用户可在头像编辑器中裁剪并保存头像	P2	已实现	裁剪区域有效，保存后页面展示新头像
FR-PRO-005	资料入口一致性	联系人、会话、搜索和群成员中的用户头像可进入资料或私聊入口	P1	已实现	入口指向正确用户，操作按双方关系展示
FR-PRO-006	资料隐私	查看他人资料时按隐私设置隐藏受限字段	P0	已实现	无权用户无法通过接口获得隐藏字段
FR-PRO-007	资料更新日志	用户资料变化后记录可同步的更新事件	P2	已实现	只返回当前用户及其联系人相关更新
FR-PRO-008	二维码名片	用户可获取用于分享账号的二维码载荷	P2	已实现	载荷包含必要公开信息且不含敏感凭据

4.3 联系人与好友申请

编号	需求	详细说明	优先级	状态	验收要点
FR-CON-001	联系人列表	用户可查看自己的联系人及相关申请	P0	已实现	只展示与当前用户相关的数据
FR-CON-002	搜索用户	用户可按用户名、昵称或用户 ID 搜索有效用户	P0	已实现	匹配正确，不泄露敏感字段
FR-CON-003	发送好友申请	用户可向符合条件的其他用户发送申请	P0	已实现	不允许向自己、已有联系人或重复申请对象创建新申请
FR-CON-004	取消好友申请	申请发起者可取消待处理申请	P1	已实现	仅发起者可取消，申请状态正确更新
FR-CON-005	接受好友申请	接收者可接受待处理申请	P0	已实现	建立联系人关系，并创建或复用私聊会话
FR-CON-006	拒绝好友申请	接收者可拒绝待处理申请	P1	已实现	不建立联系人关系，申请状态更新为拒绝
FR-CON-007	删除联系人	用户可删除已有联系人	P1	已实现	删除关系后联系人列表更新；既有聊天历史按会话规则保留
FR-CON-008	联系人发起聊天	用户可从联系人列表打开或创建私聊	P0	已实现	返回双方唯一有效的一对一会话
FR-CON-009	关系状态展示	搜索或资料结果应展示联系人、已申请、待接受等关系状态	P1	已实现	页面状态与数据库关系一致

4.4 会话列表与个人会话管理

编号	需求	详细说明	优先级	状态	验收要点
FR-CVS-001	会话列表	用户可查看自己参与的有效私聊和群聊	P0	已实现	不返回非成员会话；显示最后消息和未读信息

编号	需求	详细说明	优先级	状态	验收要点
FR-CVS-002	创建私聊	满足联系人或隐私规则的双方可创建私聊	P0	已实现	禁止与自己、无效用户或无权限对象创建会话
FR-CVS-003	私聊去重	同一对用户重复创建私聊时复用已有会话	P0	已实现	不生成重复一对一会话
FR-CVS-004	置顶会话	用户可置顶或取消置顶自己的会话	P1	已实现	只修改当前成员状态，列表排序正确
FR-CVS-005	静音会话	用户可设置或取消会话静音	P1	已实现	静音状态和期限正确保存
FR-CVS-006	归档会话	用户可归档和取消归档会话	P1	已实现	归档状态只影响当前用户视图
FR-CVS-007	隐藏会话	用户可从自己的列表隐藏会话	P2	已实现	不删除其他成员数据或底层会话
FR-CVS-008	清空聊天	用户可清空自己可见的历史消息	P1	已实现	使用成员清理时间或用户侧删除实现，不影响对方记录
FR-CVS-009	标记已读	打开会话后可清除未读计数并记录最后已读消息	P0	已实现	未读数 and 已读位置正确更新
FR-CVS-010	标记未读	用户可手动将会话标记为未读	P2	已实现	会话产生可见未读状态且不篡改消息内容
FR-CVS-011	会话自动删除	用户可设置全局或单个会话的自动删除时间	P2	已实现	超期内容按当前用户有效设置处理
FR-CVS-012	草稿保存	聊天输入草稿可保存在当前浏览器本地	P2	已实现 (本地)	切换会话后草稿可恢复且不同会话不串用

4.5 私聊消息

编号	需求	详细说明	优先级	状态	验收要点
FR-PRI-001	发送私聊消息	私聊参与者可发送符合协议的密文消息	P0	已实现	验证会话、发送者、接收者、密文字段及密钥版本
FR-PRI-002	实时接收	在线接收者通过 WebSocket 接收新消息事件	P0	已实现	事件只推送给有关用户，内容与保存记录一致
FR-PRI-003	HTTP 备用发送	WebSocket 不可用时可通过 HTTP 发送消息	P1	已实现	保存和广播语义与 WebSocket 通道一致
FR-PRI-004	历史消息	参与者可分页获取自己的私聊历史	P0	已实现	非参与者被拒绝；排序、分页和空结果正确
FR-PRI-005	发送者副本	系统保存发送者可解密的独立密文副本	P0	已实现	发送方刷新后仍可解密自己的历史消息
FR-PRI-006	消息幂等	相同客户端消息 ID 重发不产生重复消息	P0	已实现	重试后只有一条逻辑消息
FR-PRI-007	消息大小限制	服务端拒绝超过限制的密文载荷	P0	已实现	返回明确协议错误且不保存超限数据
FR-PRI-008	回复消息	用户可发送带原消息引用的回复	P1	已实现	引用目标必须位于有权访问的会话中
FR-PRI-009	送达与已读	接收者可更新消息送达和已读状态	P1	已实现	状态按权限和允许顺序更新
FR-PRI-010	拉黑限制	任一方拉黑对方后，受限制的私聊发送被拒绝	P0	已实现	HTTP 与 WebSocket 通道执行一致规则
FR-PRI-011	解密失败提示	客户端无法解密时显示明确占位，不导致页面崩溃	P1	已实现	错误被局部处理，不展示错误密文为正常明文

4.6 群聊与成员管理

编号	需求	详细说明	优先级	状态	验收要点
FR-GRP-001	创建群聊	用户可设置群名并选择成员创建群聊	P0	已实现	创建者自动成为群主，成员去重，失败时事务回滚
FR-GRP-002	修改群资料	有权限的成员可修改群名、头像等群资料	P1	已实现	普通成员和非成员不能越权修改
FR-GRP-003	邀请候选人	群管理员可查看符合条件的联系人候选列表	P1	已实现	已在群成员、无权限对象等显示或过滤原因正确
FR-GRP-004	管理员邀请	群主或管理员可直接邀请符合条件的成员	P0	已实现	成员关系和群版本正确更新
FR-GRP-005	普通成员邀请	普通成员的邀请需要管理员审核	P1	已实现	生成待审核邀请，不直接加入群聊
FR-GRP-006	审核群邀请	管理员可批准或拒绝待审核邀请	P1	已实现	只有具备权限者可审核
FR-GRP-007	受邀人响应	受邀用户可查看、接受或拒绝自己的邀请	P1	已实现	仅受邀人可操作，状态流转唯一且有效
FR-GRP-008	移除成员	群主或管理员可移除权限范围内的成员	P0	已实现	不能非法移除群主；被移除者不再接收新消息
FR-GRP-009	主动退群	非群主成员可退出群聊	P1	已实现	退出后成员失效且不再获取新群密文
FR-GRP-010	解散群聊	群主可解散群聊	P0	已实现	非群主不可解散；群状态和成员状态一致更新
FR-GRP-011	成员列表	群成员可查看有效成员和角色	P1	已实现	非成员不能获取群成员数据
FR-GRP-012	设置管理员	群主可提升或取消管理员	P1	已实现	权限层级、目标角色和作者身份校验正确

编号	需求	详细说明	优先级	状态	验收要点
FR-GRP-013	转让群主	当前群主可将群主身份转让给有效成员	P1	已实现	群主唯一，转让过程状态一致
FR-GRP-014	群公告	群管理员可创建或更新当前群公告	P2	已实现	普通成员只读，非成员不可访问
FR-GRP-015	全群静音	有权限者可设置群级静音状态	P2	已实现	权限正确，静音状态保存并作用于发送规则
FR-GRP-016	成员版本	成员变化后递增群成员版本	P0	已实现	加入、退出、移除后新消息使用最新版本

4.7 群聊消息

编号	需求	详细说明	优先级	状态	验收要点
FR-GMS-001	发送群消息	有效群成员可发送群消息逻辑记录和逐成员密文	P0	已实现	发送者和成员版本合法，接收者集合完整
FR-GMS-002	逐成员密文	每名有效接收者拥有独立密文记录	P0	已实现	用户只能获得发给自己的密文副本
FR-GMS-003	群消息实时推送	在线有效成员可接收新群消息事件	P0	已实现	非成员、已退出或已移除成员不接收新消息
FR-GMS-004	群历史消息	群成员可分页查询加入后有权查看的历史密文	P0	已实现	新成员不能查看加入前未分发给自己的消息
FR-GMS-005	群消息幂等	相同发送者和客户端消息 ID 不重复建消息	P0	已实现	网络重试不产生重复群消息
FR-GMS-006	群消息状态	支持群成员维度的送达和已读状态	P1	已实现	状态只作用于对应接收者记录
FR-GMS-007	成员变更事件	群成员变化后向相关在线成员发送事件	P1	已实现	前端能够刷新成员及密钥分发上下文

4.8 通用消息操作

编号	需求	详细说明	优先级	状态	验收要点
FR-MSG-001	用户侧删除	用户可仅删除自己视图中的指定消息	P1	已实现	不影响其他用户的消息可见性
FR-MSG-002	消息撤回	发送者可在规则允许的时间内撤回消息	P1	已实现	非发送者和超时操作被拒绝，撤回状态同步
FR-MSG-003	文本转发	用户可将有权访问的消息转发到合法目标会话	P1	已实现	校验来源权限、目标权限和转发内容
FR-MSG-004	文件转发	转发文件消息时重新分发目标接收者所需的加密文件密钥	P1	已实现	目标无权用户无法使用原会话密钥记录
FR-MSG-005	复制消息	用户可在客户端复制已解密文本	P2	已实现(本地)	复制内容来自当前用户可见明文，不经过服务端再处理
FR-MSG-006	消息状态查询	有权用户可查询消息状态详情	P2	已实现	非成员或无关用户被拒绝
FR-MSG-007	自动清理	系统可清理已超过自动删除期限的用户可见消息	P2	已实现	清理范围和用户/会话设置一致

4.9 在线状态与实时事件

编号	需求	详细说明	优先级	状态	验收要点
FR-RT-001	WebSocket 认证	只有已认证用户可建立聊天连接	P0	已实现	匿名连接被拒绝
FR-RT-002	来源校验	WebSocket 连接必须通过允许的来源校验	P0	已实现	跨站恶意来源被拒绝
FR-RT-003	在线状态	用户连接和断开时更新在线及最后上线状态	P1	已实现	状态变化与实际连接生命周期一致

编号	需求	详细说明	优先级	状态	验收要点
FR-RT-004	隐私控制	他人查看在线状态时遵守用户隐私设置	P1	已实现	无权用户只能获得允许的信息
FR-RT-005	输入中事件	会话成员可向其他有效成员广播输入中状态	P2	已实现	非成员不能向会话广播
FR-RT-006	心跳	客户端可发送 ping 并收到 pong	P2	已实现	长连接可以识别存活状态
FR-RT-007	错误处理	无效 JSON、未知事件或非法载荷返回协议错误	P0	已实现	消费者不崩溃、不泄露服务器堆栈
FR-RT-008	断线清理	连接断开后用户从相应实时组中移除	P1	已实现	后续消息不再推送到失效连接

4.10 端到端加密与密钥信任

编号	需求	详细说明	优先级	状态	验收要点
FR-KEY-001	生成身份密钥	客户端生成 ECDH 身份密钥对，私钥只保留在客户端	P0	已实现	上传请求不包含身份私钥
FR-KEY-002	上传公钥	用户可上传公钥、算法、指纹和版本	P0	已实现	指纹和版本合法，同一用户密钥版本受约束
FR-KEY-003	查询公钥	有权限用户可查询联系人当前或指定版本公钥	P0	已实现	返回公钥和指纹，不返回私钥
FR-KEY-004	批量查询公钥	群聊发送前可批量获取成员有效公钥	P0	已实现	只返回允许查询的目标及有效版本
FR-KEY-005	密钥轮换	上传新版本时保留历史公钥供历史消息解密	P0	已实现	当前密钥切换正确，旧版本仍可按权限查询
FR-KEY-006	私聊加密	客户端使用 ECDH、HKDF 和 AES-GCM 生成接收者密文	P0	已实现	服务端仅保存密文、随机数、标签、算法和版本元数据

编号	需求	详细说明	优先级	状态	验收要点
FR-KEY-007	前向保密增强	私聊支持发送者临时公钥及发送者副本加密字段	P1	已实现	接收和发送副本均可独立解密，长期身份私钥不上传
FR-KEY-008	群聊逐成员加密	同一群消息为每个有效成员生成独立密文	P0	已实现	任一成员不能获得其他成员的密文记录
FR-KEY-009	指纹展示	用户可查看本人和联系人的密钥指纹及版本	P1	已实现	指纹与实际公钥记录一致
FR-KEY-010	信任状态	用户可为联系人的具体密钥指纹保存信任状态	P1	已实现	信任记录按用户、联系人、版本隔离
FR-KEY-011	密钥变更提示	联系人密钥变化时系统可识别旧信任与新指纹差异	P1	已实现	新密钥不会自动继承旧密钥的已验证状态
FR-KEY-012	验证请求	联系人双方可发起并响应密钥验证请求	P1	已实现	仅有关双方可查看和响应，响应后信任状态正确更新
FR-KEY-013	解密失败隔离	密钥缺失、版本错误或认证失败只影响对应消息	P0	已实现	页面和其他消息继续正常工作

4.11 加密文件传输

编号	需求	详细说明	优先级	状态	验收要点
FR-FILE-001	创建上传会话	用户可为合法目标会话创建加密文件上传任务	P1	已实现	校验成员关系、文件大小、分块信息和客户端文件 ID
FR-FILE-002	分块上传	客户端可按索引上传加密文件分块	P1	已实现	索引、大小、偏移、随机数、认证标签和摘要被校验
FR-FILE-003	断点查询	客户端可查询上传状态和已完成分块	P2	已实现	只允许文件所有者或有权用户查询
FR-FILE-004	完成上传	所有合法分块上传后可完成文件并校验整体摘要	P1	已实现	缺块、大小或摘要不一致时不能完成

编号	需求	详细说明	优先级	状态	验收要点
FR-FILE-005	取消上传	文件所有者可取消未完成上传	P2	已实现	状态更新且临时分块可被清理
FR-FILE-006	文件密钥分发	客户端为每个合法持有者提交独立加密文件密钥	P0	已实现	服务端不保存文件密钥明文
FR-FILE-007	发送文件消息	已完成文件可与私聊或群聊消息关联并发送	P1	已实现	文件、会话和密钥持有者关系一致
FR-FILE-008	文件元数据	有权用户可获取加密元数据、分块信息和自己的密钥记录	P1	已实现	无关用户不能获取文件或密钥数据
FR-FILE-009	文件下载	有权用户可下载完整密文或指定密文分块	P1	已实现	下载权限、分块索引和状态校验正确
FR-FILE-010	文件生命周期	过期、取消或删除的文件不能继续被非法访问	P1	已实现	清理命令可处理过期上传，接口拒绝失效资源

4.12 搜索

编号	需求	详细说明	优先级	状态	验收要点
FR-SRC-001	统一搜索	用户可搜索自己的会话、联系人和群聊	P1	已实现	结果只包含当前用户有权查看的数据
FR-SRC-002	范围筛选	搜索可按全部、私聊、群聊等范围筛选	P2	已实现	筛选结果类型正确，非法范围安全处理
FR-SRC-003	本地明文搜索	已解密聊天内容只在当前客户端内搜索	P1	已实现（本地）	服务端统一搜索不接收或检索 E2EE 消息明文
FR-SRC-004	扩展类型入口	Channels、Apps、Posts 等未实现类型可显示空状态或占位说明	P2	界面占位	不得伪造搜索结果或宣称能力已完整实现

4.13 通知、存储、隐私与通用设置

编号	需求	详细说明	优先级	状态	验收要点
FR-SET-001	通知总开关	用户可开启或关闭通知显示	P2	已实现	设置按用户保存并正确读取
FR-SET-002	分类通知	用户可分别配置私聊、群聊和频道通知	P2	已实现	服务端保存开关；频道业务本身仍为规划能力
FR-SET-003	通知预览与声音	用户可配置消息预览、提示音和音量	P2	已实现	参数范围经过校验，刷新后配置保留
FR-SET-004	存储统计	用户可查看与自己相关的缓存分类和估算占用	P2	已实现	统计口径一致且不包含其他用户私有数据
FR-SET-005	清理缓存	用户可清理允许范围内的个人缓存数据	P2	已实现	不删除业务必要记录或他人文件
FR-SET-006	自动下载	用户可配置媒体和文件自动下载条件	P2	已实现	配置按用户保存，非法结构被清洗
FR-SET-007	隐私可见性	用户可设置手机号、在线状态、头像、简介等字段可见范围	P1	已实现	查询他人资料时按设置过滤
FR-SET-008	消息与群邀请权限	用户可限制谁能发消息、通话或邀请入群	P1	已实现	创建会话、发送消息和邀请时执行相应规则
FR-SET-009	拉黑用户	用户可拉黑和取消拉黑其他用户	P0	已实现	拉黑关系唯一，相关发送与资料访问受限
FR-SET-010	举报会话	用户可对自己参与的会话提交原因和说明	P2	已实现	非成员不能举报无关会话，举报记录可追踪
FR-SET-011	删除同步联系人	用户可请求删除自己的同步联系人关系	P2	已实现	只影响当前用户范围并返回明确结果
FR-SET-012	删除账号	用户可发起账号删除操作	P1	已实现	需校验身份，删除/停用后登录会话失效

编号	需求	详细说明	优先级	状态	验收要点
FR-SET-013	通用设置	用户可保存主题、语言、布局等通用配置	P2	已实现	配置结构被清洗并按用户保存；部分即时外观状态保存在本地
FR-SET-014	聊天文件夹	用户可保存聊天文件夹配置	P2	已实现	配置按用户隔离，非法结构不直接写入
FR-SET-015	主题切换	用户可在浅色与深色主题间切换	P2	已实现（本地）	选择在浏览器本地保存并在刷新后恢复
FR-SET-016	语言切换	用户可切换界面支持的语言	P2	已实现（本地）	已翻译元素更新，选择可持久化
FR-SET-017	密码锁	设置页展示密码锁相关入口和状态字段	P2	界面占位	当前不作为完整密码锁功能验收
FR-SET-018	两步验证	设置页展示两步验证相关入口和状态字段	P2	界面占位	当前不作为完整二次认证功能验收
FR-SET-019	通行密钥	设置页展示 Passkey 相关入口和状态字段	P2	界面占位	当前不包含 WebAuthn 注册与认证闭环
FR-SET-020	贴纸、生日和快捷页面	系统提供相应设置页面和基础交互入口	P2	部分实现	只验收现有页面展示和已实现交互，不扩展为完整云同步能力

4.14 AI Assistant

编号	需求	详细说明	优先级	状态	验收要点
FR-AI-001	助手入口	登录用户可从聊天界面打开 AI Assistant 面板	P2	已实现	不作为普通私聊或群成员加入会话
FR-AI-002	助手会话管理	用户可在客户端创建、切换、重命名和删除助手会话	P2	已实现（本地）	不同助手会话的历史和配置互不混用
FR-AI-003	模型配置	用户可为指定助手配置服务地址、模型和 API Key	P2	已实现	配置按用户和助手隔离；敏感值不在普通状态接口明文返回

编号	需求	详细说明	优先级	状态	验收要点
FR-AI-004	服务地址安全	外部模型地址必须使用 HTTPS 且主机满足允许规则	P0	已实现	HTTP、回环、私网或未允许目标按策略拒绝，降低 SSRF 风险
FR-AI-005	Mock 模式	无真实服务配置时可使用 Mock Provider 演示	P2	已实现	无 API Key 时核心聊天系统不受影响
FR-AI-006	兼容模型服务	支持 OpenAI 兼容接口和 Anthropic Messages 风格接口	P2	已实现	请求、响应和流式结果被正确标准化
FR-AI-007	对话请求	用户主动输入内容后可获取模型响应	P2	已实现	空输入、超时、上游错误和无效配置有明确提示
FR-AI-008	隐私隔离	AI Assistant 不自动读取 E2EE 私聊/群聊明文、私钥或文件密钥	P0	已实现约束	只有用户主动提交到助手的内容进入模型请求

4.15 管理后台与审计

编号	需求	详细说明	优先级	状态	验收要点
FR-ADM-001	管理后台	授权管理员可进入 Django 管理后台管理注册模型	P2	已实现	非管理员不能进入后台
FR-ADM-002	用户管理	管理员可查看基础用户信息并停用或恢复账号	P2	已实现	操作权限正确，停用后用户不能登录
FR-ADM-003	群组与记录管理	管理员可查看群组、密文消息和举报等管理数据	P2	已实现	管理员只能看到服务端实际保存的密文及元数据
FR-ADM-004	操作日志	关键管理员操作应记录操作者、对象、动作和时间	P2	已实现	日志可追踪且普通用户不能修改
FR-ADM-005	明文隔离	管理员不得通过后台直接查看 E2EE 消息和文件明文	P0	已实现约束	数据模型及后台不保存相应明文字段

4.16 Electron 桌面端

编号	需求	详细说明	优先级	状态	验收要点
FR-DESK-001	桌面窗口	Electron 创建承载 iChat Pro 的桌面窗口	P2	已实现	窗口可加载登录页和聊天主界面
FR-DESK-002	本地服务启动	桌面端可按配置启动本地 Django 服务	P2	已实现	服务地址和端口可配置，启动失败有可诊断信息
FR-DESK-003	跳过服务启动	可通过环境变量让 Electron 直接连接已运行服务	P2	已实现	<code>ICCHAT_SKIP_DJANGO=1</code> 时不重复启动服务
FR-DESK-004	安全桥接	预加载脚本只暴露必要的桌面环境信息	P1	已实现	页面不直接获得不必要的 Node.js 权限
FR-DESK-005	业务一致性	Electron 与浏览器共用相同后端和主要页面功能	P2	已实现	不产生独立账号、会话或消息数据源

5. 界面需求

5.1 总体布局

- 桌面聊天界面采用侧边栏、聊天区和信息面板组成的分区布局。
- 联系人、设置、群组等子页面优先在侧边栏区域切换，聊天区保持上下文。
- 当前会话、未读数、在线状态和操作状态应具有清晰视觉反馈。
- 页面应支持浅色和深色主题，文字与背景保持基本可读对比度。
- 主要按钮、输入框、菜单和提示不得被常见窗口尺寸遮挡。

5.2 认证页面

- 登录页应提供用户名/邮箱输入框、密码输入框、登录按钮和注册链接。
- 注册页应提供完整注册字段、提交按钮及返回登录入口。
- 字段错误应在页面上以用户可理解的语言显示，不展示异常堆栈。
- 表单应支持键盘操作，密码字段不以明文默认显示。

5.3 聊天页面

- 会话列表应展示名称、头像、最后消息摘要、时间、未读及置顶/静音状态。
- 聊天头部应展示目标用户或群组基本信息及相关操作入口。
- 消息区应区分发送和接收消息，并显示发送状态、时间、回复或文件信息。
- 输入区应支持文本输入、发送、文件入口和必要的失败反馈。

- 解密失败、网络中断、权限失败和文件失效必须显示明确状态。

5.4 设置页面

- 设置首页应提供个人资料、通知、隐私、安全、数据和存储、通用设置等入口。
- 已实现设置应能读取当前值、修改并保存。
- 尚未形成完整闭环的设置必须显示为占位或未实现，不能伪装为可用。

6. 数据需求

6.1 主要数据实体

数据域	主要实体	用途
用户	Django User、UserProfile	身份认证与资料
隐私设置	UserPrivacySettings、BlockedUser	可见性、消息权限和拉黑关系
用户设置	UserStorageSettings、UserNotificationSettings、UserGeneralSettings、UserChatFolderSettings	个性化配置
联系人	FriendRequest、Contact	好友申请状态和联系人关系
密钥	UserPublicKey、KeyTrust、KeyVerificationRequest	公钥版本、信任和验证流程
会话	Conversation、ConversationMember	私聊/群聊容器及成员个性状态
私聊消息	EncryptedMessage	私聊密文、密钥版本、状态和回复关系
群聊消息	GroupMessage、GroupMessageRecipient	群消息逻辑记录和逐成员密文
消息管理	UserMessageDeletion、ChatReport	用户侧删除和举报
实时状态	UserPresence	在线状态、最后上线时间和可见性
群管理	GroupInvitation、GroupAnnouncement	邀请审批和群公告
文件	EncryptedFile、EncryptedFileChunk、EncryptedFileKey	加密文件、分块和逐用户密钥
AI	UserLLMConfig	按用户和助手隔离的模型服务配置
审计	AdminOperationLog、UserProfileUpdateLog	管理操作和资料变化记录

6.2 数据完整性规则

1. 用户名、好友关系、会话成员关系、消息客户端标识等唯一性由数据库约束和业务校验共同保证。
2. 好友申请、群邀请、消息状态和文件状态必须使用定义的有限状态值。
3. 私聊会话必须且只应包含合法的两名有效参与者。
4. 群主在有效群聊中应保持唯一；角色变更不得产生无群主状态。
5. 群消息接收者记录必须关联同一群消息和唯一接收用户。
6. 文件分块索引在单个文件内唯一，完成前必须满足分块数量和摘要要求。
7. 私钥、会话密钥、文件密钥明文和 E2EE 消息明文不得保存到服务端数据库。
8. 用户删除、退出或清理操作不得越权修改其他用户独立数据。

6.3 数据保留与清理

- 会话清空和用户侧删除默认只改变当前用户可见性。
- 自动删除设置按用户和会话的有效规则计算。
- 过期或取消的临时上传应由清理命令移除。
- 数据库备份、测试数据库、媒体缓存和运行日志不属于源代码交付物。
- 正式环境中的业务数据删除需遵守课程演示口径和实际部署策略。

7. 外部接口需求

7.1 HTTP 接口

1. 页面接口返回 HTML，业务接口主要返回 JSON 或文件流。
2. 写操作应限制允许的 HTTP 方法并执行身份、权限和 CSRF 校验。
3. 参数错误使用 400 类响应；未认证、无权限和资源不存在应使用相应语义响应。
4. JSON 错误响应应包含稳定错误码或可理解说明，不返回调试堆栈。
5. 上传下载接口必须执行会话成员和文件持有者权限校验。

7.2 WebSocket 接口

1. 连接阶段验证用户会话和请求来源。
2. 消息事件采用结构化 JSON，至少包含事件类型和业务数据。
3. 无效 JSON、未知事件、缺失字段和越权事件应返回可识别错误。
4. 私聊事件仅发送给通信双方；群聊事件仅发送给有效成员。
5. HTTP fallback 与 WebSocket 对同一业务规则应保持一致。

7.3 AI 服务接口

1. 外部端点必须使用 HTTPS 并通过主机允许规则。
2. 系统支持 OpenAI 兼容 Chat Completions 及 Anthropic Messages 风格协议。
3. 外部服务失败、超时或返回异常时，系统应提供明确错误或安全回退。
4. 模型请求只包含用户主动输入的助手内容及必要系统提示。

7.4 文件系统接口

- 1. 媒体、头像和加密文件只能写入配置允许的目录。
- 2. 文件名、上传 ID 和存储路径不得允许目录穿越。
- 3. 服务端存储的是加密文件内容，不应保存客户端文件密钥明文。

8. 非功能需求

8.1 安全性

编号	需求	验收指标
NFR-SEC-001	密码使用 Django 密码散列机制保存	数据库不存在密码明文
NFR-SEC-002	所有用户私有接口执行身份认证和对象级权限校验	匿名和越权用例无法获取或修改数据
NFR-SEC-003	E2EE 明文和私钥不进入服务端	数据库、HTTP 和 WebSocket 服务端载荷检查不出现对应明文字段
NFR-SEC-004	正式环境启用 HTTPS、HSTS、安全 Cookie 和内容类型保护	<code>DEBUG=False</code> 时相关安全配置生效
NFR-SEC-005	正式环境必须显式设置密钥	未配置 <code>DJANGO_SECRET_KEY</code> 时拒绝以正式模式启动
NFR-SEC-006	登录错误避免账号枚举，跳转避免开放重定向	对应异常输入测试通过
NFR-SEC-007	AI 外部端点受 SSRF 防护约束	不安全 URL 和未允许主机被拒绝
NFR-SEC-008	文件上传执行大小、摘要、分块和权限校验	非法文件请求不落为有效文件

8.2 可靠性与一致性

编号	需求	验收指标
NFR-REL-001	好友接受、建群和关键状态变更使用事务保证一致性	中途失败不产生半完成关系
NFR-REL-002	私聊和群聊消息支持客户端 ID 幂等	重复提交不产生重复逻辑消息
NFR-REL-003	WebSocket 失败时提供 HTTP 备用发送	备用路径遵守同一权限和数据规则
NFR-REL-004	单条消息解密失败不影响其他消息和页面	错误被局部展示，页面仍可操作

编号	需求	验收指标
NFR-REL-005	外部 AI 服务故障不影响核心通信功能	助手失败时私聊和群聊仍可使用

8.3 性能

编号	需求	建议验收指标
NFR-PER-001	常规页面和本地接口具备可接受响应时间	课程环境下 95% 普通 HTTP 请求不高于 2 秒
NFR-PER-002	在线消息具有可接受延迟	本机或局域测试中消息可见延迟通常不高于 1 秒
NFR-PER-003	历史消息和搜索使用分页或结果限制	大量数据时单次响应不返回无限记录
NFR-PER-004	文件采用分块传输	单块失败可重试，无需重新上传全部文件

性能阈值需在后续测试计划中结合课程设备、网络和数据规模最终确认。

8.4 易用性与可访问性

1. 核心流程的主要操作入口应清晰可见，错误信息应可理解。
2. 相同操作在不同页面应使用一致术语、图标和反馈方式。
3. 页面应支持常见桌面窗口尺寸，重要操作不因缩放被遮挡。
4. 表单应具备标签、焦点和键盘提交能力。
5. 深浅主题下文字、按钮和状态应具有足够可辨识度。

8.5 兼容性

1. 核心 Web 功能至少支持课程指定的当前 Chromium 浏览器。
2. 使用 Web Crypto API 的浏览器必须提供安全上下文及所需算法。
3. Electron 使用的 Chromium 内核应与 Web 页面主要功能兼容。
4. Windows 为主要课程实验环境；自动化测试应能在 GitHub Actions 的 Linux 环境运行。

8.6 可维护性与可测试性

1. 账号功能归入 `accounts`，聊天相关功能归入 `chat`，项目配置归入 `ichat_pro`。
2. 数据结构变化通过 Django migrations 管理，不直接修改已交付数据库结构。
3. 每项核心需求应有唯一编号，并可关联任务、用例、缺陷和提交。
4. 核心后端功能使用 Django TestCase/TransactionTestCase 测试；前端加密逻辑使用 Node.js 测试。
5. 合并前至少执行 Django 配置检查、迁移检查和核心自动化测试。
6. 测试数据、密钥、数据库和本地依赖不得提交为正式源码。

9. 核心业务规则

9.1 账号规则

1. 用户名必须唯一，邮箱登录仅匹配已存在的绑定邮箱。
2. 账号被禁用后不能建立新的登录会话。
3. 用户只能修改自己的资料、设置和会话状态。

9.2 联系人规则

1. 用户不能将自己添加为联系人。
2. 双方已是联系人时不能再创建有效好友申请。
3. 同一对用户不能同时存在多个等价的待处理申请。
4. 只有接收者可以接受或拒绝申请，只有发起者可以取消申请。
5. 一条 Contact 关系在当前业务语义中代表双方互为联系人。

9.3 私聊规则

1. 创建新私聊必须通过联系人、隐私、账号状态和拉黑规则。
2. 已存在有效私聊时必须复用，不能创建重复会话。
3. 只有有效会话成员可读取历史、发送消息或修改消息状态。
4. 删除联系人不应自动删除已经存在且仍有效的历史会话。

9.4 群聊规则

1. 创建者自动成为群主，一个有效群聊只能有一名群主。
2. 普通成员邀请需要管理员审核；群主和管理员按权限直接邀请。
3. 新成员只能获得加入后为其生成的群消息密文。
4. 退出或被移除成员不能接收新的群消息和密钥。
5. 群成员变化必须更新成员版本，以防使用过期成员列表分发密文。

9.5 消息与加密规则

1. 服务端不接受客户端将聊天明文作为持久化字段提交。
2. 加密载荷必须包含协议要求的密文、随机数、认证信息、算法和密钥版本。
3. 发送者副本与接收者副本分别保存，满足双方历史解密需要。
4. 消息客户端 ID 用于识别网络重试，不能作为越权覆盖其他消息的手段。
5. 撤回、删除、转发、已读等操作必须验证操作者与消息关系。

9.6 文件规则

1. 文件在客户端加密后上传，服务端只保存密文分块。
2. 每个有权解密文件的用户拥有独立的加密文件密钥记录。
3. 文件转发到新会话时必须为新目标重新准备合法密钥记录。
4. 文件未完成、已取消、已删除或已过期时不得作为正常文件发送或下载。

9.7 AI Assistant 规则

1. AI Assistant 是独立辅助面板，不是联系人、Bot 用户或会话成员。
2. AI Assistant 不自动读取现有私聊、群聊、私钥、会话密钥或文件密钥。
3. 用户必须主动输入或粘贴内容后才能向模型服务发送。
4. 模型配置按用户和助手隔离，不得使用其他用户配置。

10. 当前范围外与后续规划

以下能力不是当前版本的完整交付需求，不得按“已实现功能”验收：

1. 语音通话和视频通话。
2. 移动端原生 App。
3. 完整的 Signal Protocol、Double Ratchet 或 Sender Key 协议。
4. 真正的 P2P 网络通信。
5. 完整多设备密钥同步与冲突处理。
6. Channel、完整 Bot、Agent Gateway、RAG 知识库和长期记忆。
7. WebAuthn Passkey、完整密码锁和完整两步验证闭环。
8. 完整云端贴纸、生日提醒和全局快捷键同步。
9. 面向大规模公网部署的高并发、容灾及内容审核体系。

11. 验收原则

11.1 功能验收

- P0 需求必须实现并通过正常、异常及关键安全场景测试。
- P1 需求原则上应实现；未通过项必须登记缺陷、影响和处理计划。
- P2 需求按课程时间验收已有实现，不得将占位入口判定为完整功能。
- “已实现”状态必须由实际代码、执行结果和证据共同确认。

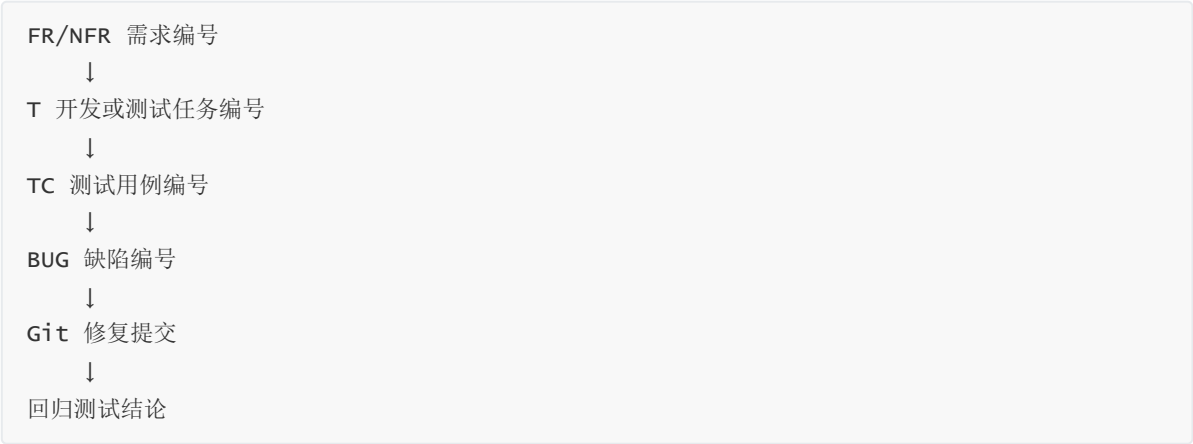
11.2 测试证据

每项测试至少记录以下信息：

1. 需求编号和测试用例编号；
2. 测试环境、前置条件和测试数据；
3. 操作步骤或自动化测试命令；
4. 预期结果和实际结果；
5. 通过/不通过状态；
6. 截图、日志或自动化测试输出；
7. 发现缺陷时的缺陷编号和回归结果。

11.3 需求追踪

后续文档应使用如下关系维护可追溯性：



12. 需求评审清单

- ☐ 项目名称、版本、小组信息和评审人员已填写。
- ☐ 每项需求均具有唯一编号、明确状态和优先级。
- ☐ 已实现、部分实现、界面占位和规划能力没有混淆。
- ☐ 功能需求与当前页面、接口、模型和业务规则一致。
- ☐ P0 安全需求均具有可执行的验收方式。
- ☐ 性能指标已结合实际实验环境确认。
- ☐ 后续任务、测试用例和缺陷记录能够引用需求编号。
- ☐ 所有小组成员已完成评审并确认需求基线。

附录 A：新旧需求关系

类别	需求编号	本学期定位
继承功能	FR-*	上学期成果，作为回归基线和新客户端/云环境的被测业务
Windows 产品化	NEW-WIN-*	本学期新增产品成果
Android 产品化	NEW-AND-*	本学期新增产品成果
跨平台一致性	NEW-XP-*	本学期新增集成成果
云端部署	NEW-CLD-*	本学期新增工程成果
可靠通信	NEW-REL-*	本学期新增质量与功能成果
多设备密钥	NEW-DEV-*	本学期新增安全研究与实现成果
产业级测试	NEW-TST-*	本课程核心成果
CI/CD 门禁	NEW-CI-*	本学期新增测试工程成果
通用非功能需求	NFR-*	新旧功能共同遵守的质量约束

本学期应以 **NEW-*** 需求的实现和验证作为主要评分证据，既有 **FR-*** 需求用于证明迁移到云端和多客户端后没有发生功能回归。

附录 B：最终综合验收场景

建议最终答辩至少连续完成以下综合场景：

1. 在一台干净 Windows 设备安装 iChat Pro Windows App。
2. 在一台 Android 真机或独立模拟器安装 iChat Pro Android App。
3. 两端通过公网 HTTPS/WSS 连接同一云服务器。
4. 两名用户登录、建立联系人关系并完成双向私聊。
5. Android 切断网络，Windows 继续发送消息；Android 恢复网络后自动重连并补取消息。
6. 验证消息没有重复，顺序、送达和已读状态正确。
7. 创建群聊并完成跨端群消息及加密文件传输。
8. 展示云端 PostgreSQL、Redis、持久化文件、健康检查和监控状态。
9. 展示服务端数据库或日志中不存在聊天明文、私钥和文件密钥明文。
10. 展示 CI 流水线、黑盒用例、白盒覆盖率、安全/性能结果及一个真实缺陷闭环。